

Dan Boneh 密码学专题：PRG、PRF、PRP 的区别与联系

本笔记用于复习 Dan Boneh 《Cryptography I》中反复出现的三个基础概念：伪随机生成器 PRG、伪随机函数 PRF 和伪随机置换 PRP。

1. 先看结论

三者都试图让一个由短密钥或短种子决定的确定性对象，在计算上看起来像真正的随机对象，但它们模拟的目标不同：

概念	中文名称	模拟的随机对象	最核心的特征
PRG	伪随机生成器	一段均匀随机的长比特串	短种子扩展成长输出
PRF	伪随机函数	从输入集到输出集的随机函数	同一密钥下可计算许多输入
PRP	伪随机置换	定义域上的随机置换	可逆，且不同输入不会映射到同一输出

最简记忆法：

- PRG：一个种子生成一段长串；
- PRF：给定密钥，可以像调用函数一样反复查询；
- PRP：一种特殊的 PRF，要求输入输出等长并且可逆。

但是，“PRP 是一种特殊 PRF”描述的是结构关系。严格讨论安全性时，安全 PRP 与安全 PRF 的判定实验不同，二者只能在查询次数较少时通过 PRP/PRF Switching Lemma 联系起来。

2. 共同背景：什么叫伪随机

PRG、PRF 和 PRP 都是确定性算法。只要种子或密钥固定，同一输入就会产生同一输出。

所谓伪随机，不是输出在数学上真的随机，而是：

对任何现实可行的高效攻击者，真实构造与理想随机对象在计算上不可区分。

通常用区分实验表达：

1. 挑战者随机选择真实世界或理想世界；
2. 攻击者观察输出或访问一个接口；
3. 攻击者猜自己处于哪个世界；
4. 若攻击者的成功优势只能忽略不计，就称该对象安全。

因此，理解三者的关键是问：它在理想世界中模仿的究竟是什么？

3. PRG：伪随机生成器

3.1 定义

伪随机生成器是一个确定性算法：

$$G : \{0, 1\}^s \rightarrow \{0, 1\}^n, \quad n > s.$$

- s 是种子长度；
- n 是输出长度；
- $n-s$ 称为扩展量；
- 输入种子必须随机且不可预测。

例如：

$$G : \{0, 1\}^{128} \rightarrow \{0, 1\}^{1024}.$$

它用 128 位种子产生 1024 位伪随机输出。

3.2 安全实验

攻击者需要区分：

真实世界：

$$k \leftarrow \{0, 1\}^s, \quad y = G(k).$$

理想世界：

$$r \leftarrow \{0, 1\}^n.$$

PRG 安全要求 $G(k)$ 与均匀随机的 n 位串在计算上不可区分：

$$G(U_s) \approx_c U_n.$$

其中 U_s 和 U_n 分别表示均匀随机的 s 位和 n 位字符串， $\approx_c$ 表示计算不可区分。

3.3 为什么它不可能统计上均匀

G 最多只有 2^s 种不同输出，而 n 位随机串共有 2^n 种。当 $n > s$ 时：

$$2^s < 2^n.$$

所以绝大多数 n 位字符串永远不会成为 G 的输出。如果攻击者拥有无限计算能力，只需判断给定字符串是否位于 G 的像集中，就能区分它。

PRG 追求的只能是**计算安全性**：像集虽然很小，但高效攻击者无法识别。

3.4 在流密码中的作用

用共享密钥 k 作为种子，生成与消息等长的密钥流：

$$c = m \oplus G(k).$$

解密为：

$$m = c \oplus G(k).$$

这与一次一密的形式相似，但 $G(k)$ 不是真正随机串。安全性的关键是 $G(k)$ 对高效攻击者而言像随机串。

必须注意：同一个密钥流不能重复用于两条消息。若：

$$c_1 = m_1 \oplus G(k), \quad c_2 = m_2 \oplus G(k),$$

则：

$$c_1 \oplus c_2 = m_1 \oplus m_2,$$

密钥流被消掉，消息关系随之泄露。

3.5 PRG 的观察方式

在最基本的安全游戏中，攻击者得到的是一整段输出，再判断它来自 PRG 还是真随机源。它不像 PRF 那样提供可自由选择多个输入的查询接口。

4. PRF：伪随机函数

4.1 定义

伪随机函数是一族由密钥索引的确定性函数：

$$F : K \times X \rightarrow Y.$$

固定密钥 k 后，得到一个普通函数：

$$F(k, \cdot) : X \rightarrow Y.$$

这里的点号表示“这个位置留给函数输入”。例如 $F(k, x)$ 中固定 k ，让 x 变化，就得到函数 $F(k, \cdot)$ 。

4.2 它模仿什么

PRF 模仿的是从 X 到 Y 随机选出的一个函数：

$$f \leftarrow \text{Func}[X, Y].$$

随机函数不是每次查询都重新抛硬币。它必须保持函数的一致性：

- 第一次查询 x 时，随机选取 y 并记录 $f(x)=y$ ；
- 再次查询同一个 x ，必须返回同一个 y ；
- 不同输入的输出可以相同。

4.3 安全实验

攻击者可以自适应地选择多个输入，访问以下两个接口之一：

真实世界：

$$O(x) = F(k, x), \quad k \leftarrow K.$$

理想世界：

$$O(x) = f(x), \quad f \leftarrow \text{Func}[X, Y].$$

如果攻击者无法判断自己访问的是 $F(k, \cdot)$ 还是真随机函数 f ，则 F 是安全 PRF。

区分优势可写为：

$$\text{Adv}_{PRF}[A, F] = \left| \Pr[A^{F(k, \cdot)} = 1] - \Pr[A^f = 1] \right|.$$

4.4 PRF 与普通哈希函数的区别

PRF	普通密码学哈希函数
带秘密密钥	通常不带密钥
安全目标是模仿随机函数	可能强调抗碰撞、原像抗性等
同一输入在不同密钥下输出不同	同一输入总得到公开固定的摘要
可用于 MAC、密钥派生等	可用于摘要、完整性指纹等

HMAC 在适当假设下可作为 PRF 使用，但不能因此把所有哈希函数都称为 PRF。

4.5 PRF 的用途

PRF 常用于：

- 构造消息认证码；
- 从主密钥派生子密钥；
- 构造确定性计数器模式密钥流；
- 生成与上下文绑定的伪随机值。

例如使用不同计数器作为输入：

$$F(k, 0) \parallel F(k, 1) \parallel F(k, 2) \parallel \dots$$

可以生成较长的伪随机输出，但必须保证输入编码与使用方式正确。

5. PRP：伪随机置换

5.1 定义

伪随机置换是一族由密钥索引的可逆函数。通常定义域与值域相同：

$$E : K \times X \rightarrow X.$$

对每个固定密钥 k ：

$$E(k, \cdot) : X \rightarrow X$$

必须是一个双射，因此存在高效逆函数：

$$D(k, E(k, x)) = x.$$

分组密码就是 PRP 的典型候选。例如 AES 对固定密钥 k 而言，把 128 位输入块置换为 128 位输出块。

5.2 它模仿什么

PRP 模仿从 X 上所有置换中均匀随机选出的一个置换：

$$\pi \leftarrow \text{Perm}[X].$$

真实世界为 $E(k, \cdot)$ ，理想世界为随机置换 π 。安全的 PRP 要求高效攻击者不能区分两者。

5.3 置换的关键限制

若 $x_1 \neq x_2$ ，则置换一定满足：

$$E(k, x_1) \neq E(k, x_2).$$

因为它必须可逆。随机函数则没有这一限制：不同输入可能碰巧得到相同输出。

这正是随机置换和随机函数之间最重要的可观察差别。

5.4 PRP 与强 PRP

普通 PRP 安全实验通常只让攻击者查询正向接口 $E(k, \cdot)$ 。

强 PRP，也常写作 SPRP，允许攻击者同时查询：

$$E(k, \cdot) \quad \text{和} \quad D(k, \cdot).$$

理想世界相应提供随机置换 π 及其逆置换 π^{-1} 。能够抵抗双向查询是更强的要求。

5.5 分组密码为何只处理固定长度

AES 的分组长度固定为 128 位，因此 AES 本身只能把一个 128 位块置换成另一个 128 位块。要加密任意长度消息，必须使用 CBC、CTR、GCM 等工作模式。

所以，“分组密码”不是简单地把消息分组后逐块独立加密。直接逐块独立使用会形成 ECB，并泄露重复分组的模式。

6. 三者的核心区别

6.1 输入输出结构

比较项	PRG	PRF	PRP
形式	$G(s)$	$F(k,x)$	$E(k,x)$
秘密值	随机种子 s	随机密钥 k	随机密钥 k
外部输入	通常没有额外查询输入	有输入 x	有固定长度输入 x
输出	比种子更长的比特串	固定或规定长度的函数值	与输入同域的值
必须可逆	否	否	是
允许输出碰撞	不以此定义	允许	不允许
理想参照物	均匀随机长串	随机函数	随机置换
典型实例	密码学安全生成器	HMAC、专用 PRF	AES 等分组密码

6.2 安全实验中的攻击者能力

- PRG：通常只观察一个挑战字符串；
- PRF：可选择多个输入并查询函数接口；
- PRP：可查询置换接口，强 PRP 中还可查询逆接口。

因此，不能仅看输出“像随机”就认为三者定义相同。攻击者能如何与对象交互，是安全定义的一部分。

6.3 随机函数与随机置换的差别

假设 $X=Y=\{0,1\}^n$ 。

随机函数：

- 每个输入独立关联一个随机 n 位输出；
- 不同输入可能映射到同一输出；
- 通常不可逆。

随机置换：

- 所有输出是一一对应的重新排列；
- 不同输入绝不发生输出碰撞；
- 一定存在逆函数。

7. PRP 为什么有时可以当作 PRF

7.1 攻击者的区分方法

给定一个未知接口，攻击者可查询许多不同输入并观察输出：

- 若出现输出碰撞，它一定不是置换；
- 若始终无碰撞，则更像置换。

但在 n 位输出空间中，随机函数大约需要 $2^{n/2}$ 次查询才有较明显的碰撞概率。因此，当查询次数 q 远小于 $2^{n/2}$ 时，随机函数与随机置换看起来很接近。

7.2 PRP/PRF Switching Lemma

对于 n 位定义域， q 次查询造成的区分差距大约受以下生日项控制：

$$O\left(\frac{q^2}{2^n}\right).$$

因此，一个安全 PRP 在查询次数显著小于 $2^{n/2}$ 时，常可作为 PRF 使用，并在安全证明中加上这一转换损失。

注意：这不是说随机置换在数学上等于随机函数。二者在查询足够多时可以被区分。

7.3 AES 的例子

AES 的分组长度为 128 位。若把 AES 看作 PRF，其与随机函数之间由“不会出现输出碰撞”导致的差异大致按 $q^2/2^{128}$ 增长。

这也是密码学中频繁出现生日界的原因之一。

8. 三者之间如何构造

8.1 用 PRF 构造 PRG

固定若干不同输入，将 PRF 输出拼接：

$$G(k) = F(k, 0) \parallel F(k, 1) \parallel \cdots \parallel F(k, t).$$

若 F 是安全 PRF，并且输入编码互不相同，这些输出对攻击者而言像独立随机值，拼接后便得到较长伪随机串。

8.2 用 PRP 构造 PRF

安全 PRP 可在生日界允许的查询范围内，通过 PRP/PRF Switching Lemma 当作 PRF 使用。这里存在大约 $q^2/2^n$ 的安全损失。

8.3 用 PRG 构造 PRF

理论上，可以通过 Goldreich–Goldwasser–Micali，即 GGM 构造，把一个安全 PRG 逐层扩展成 PRF。

这说明在理论密码学中，PRG 是构造更复杂伪随机对象的重要基础。但这并不意味着把 PRG 输出随意切块，就自动获得一个可安全接受任意输入的 PRF；必须使用经过证明的构造。

8.4 不应画成简单强弱链

不应直接写成：

$$PRG < PRF < PRP$$

因为它们的接口和理想对象不同。更准确的说法是：

- 安全 PRG 可通过特定构造得到 PRF；
- PRF 可在固定不同输入上产生 PRG 式长输出；
- 安全 PRP 在生日界以内可近似作为 PRF；
- PRP 比同域 PRF 多出可逆和无碰撞的结构限制。

9. 一个直观类比

假设有一本由秘密值决定的“答案书”：

PRG

给定一个秘密种子，机器一次吐出一条很长的数字串。你只能判断这串数字像不像真正随机生成的。

PRF

你可以向答案书询问任意题号 x 。相同题号总返回相同答案，不同题号的答案看起来相互独立，但偶尔可以相同。

PRP

题号和答案来自同一个有限集合，而且每个答案恰好只属于一个题号。答案不能重复，还能从答案唯一找回题号。

类比只帮助建立直觉，正式分析仍应回到各自的区分实验。

10. 常见误区

误区 1：PRG 输出是真随机的

错误。它由短种子确定，而且可能输出的字符串只占有所有长字符串中的很小一部分。它只是对高效攻击者而言难以与真随机区分。

误区 2：固定密钥后的 PRF 每次查询都会产生新随机数

错误。PRF 是确定性函数，同一个密钥和同一个输入永远得到相同输出。

误区 3：随机函数对同一输入可以返回不同结果

错误。安全实验中的随机函数也必须保持函数一致性，同一输入始终对应同一输出。

误区 4：PRF 一定可逆

错误。PRF 不要求可逆，也允许不同输入产生相同输出。可逆性是 PRP 的结构要求。

误区 5：PRP 与随机函数完全一样

错误。PRP 不会出现输出碰撞，随机函数会。只是在查询数低于生日界时，这种差别难以观察。

误区 6：AES 可以直接加密任意长消息

错误。AES 是 128 位分组上的 PRP 候选，需要配合安全工作模式处理长消息。

误区 7：同一个 PRG 密钥流可以反复使用

错误。在最简单的异或流密码中，重复密钥流会泄露两条明文的异或关系。

误区 8：知道一种对象存在，就能随意实现另一种对象

错误。三者之间的转换必须采用有明确安全证明的构造，并满足输入唯一性、查询上限等条件。

11. 必记公式

PRG:

$$G : \{0, 1\}^s \rightarrow \{0, 1\}^n, \quad n > s,$$
$$G(U_s) \approx_c U_n.$$

PRF:

$$F : K \times X \rightarrow Y,$$
$$F(k, \cdot) \approx_c f, \quad f \leftarrow \text{Func}[X, Y].$$

PRP:

$$E : K \times X \rightarrow X,$$
$$E(k, \cdot) \approx_c \pi, \quad \pi \leftarrow \text{Perm}[X].$$

可逆性:

$$D(k, E(k, x)) = x.$$

PRP 与 PRF 的生日界差距:

$$O\left(\frac{q^2}{2^n}\right).$$

12. 自测题

题目

1. PRG 为什么必须满足输出长度大于种子长度?
2. PRG 的输出为什么不可能在信息论意义上等同于均匀随机长串?
3. PRF 的理想对象是什么? 它对重复输入如何响应?
4. PRF 和普通无密钥哈希函数最直接的区别是什么?
5. PRP 比 PRF 多了哪两项关键结构要求?
6. 随机函数和随机置换如何通过输出碰撞区分?
7. 为什么查询次数少时安全 PRP 常能当作 PRF 使用?
8. AES 本身是 PRG、PRF 还是 PRP 的典型候选?
9. 能否简单地说 PRP 比 PRF 更安全?
10. 如何用 PRF 生成较长伪随机串?

参考答案

1. PRG 的用途就是从短随机种子扩展出更长的伪随机性; 若没有扩展, 就没有完成生成器的核心任务。
 2. s 位种子最多产生 2^s 个输出, 而 n 位字符串共有 2^n 个; 当 $n > s$ 时, PRG 输出只覆盖很小的子集。
 3. 理想对象是随机函数。同一输入必须始终返回同一输出, 因为它仍然是一个函数。
 4. PRF 带秘密密钥并模仿随机函数; 普通哈希通常公开且无密钥, 强调抗碰撞、原像抗性等性质。
 5. 固定密钥后必须为双射, 并且存在高效逆运算。因此输入输出同域且不会发生输出碰撞。
 6. 查询不同输入; 若观察到相同输出, 就能确定接口不是置换。随机函数在约生日界数量的查询后较可能发生碰撞。
 7. 当 q 远小于 $2^{(n/2)}$ 时, 随机函数发生输出碰撞的概率约为 $q^2/2^n$, 很难观察到它与随机置换的差别。
 8. PRP。AES 对每个密钥都在 128 位分组上定义一个可逆置换。
 9. 不能。二者模拟的理想对象和接口不同。PRP 有更强的结构限制, 但安全强弱必须依据具体安全实验和使用方式讨论。
 10. 在同一密钥下对多个互不相同、编码明确的输入调用 F , 并拼接 $F(k, 0)$ 、 $F(k, 1)$ 等输出。
-

13. 一分钟复习

1. PRG: 短种子 s $\rightarrow$ 长伪随机串; 理想对象是均匀随机长串。
2. PRF: 密钥 k + 输入 x $\rightarrow$ 输出; 固定密钥后模仿一个随机函数。
3. PRP: 可逆的同域带密钥函数; 固定密钥后模仿一个随机置换。
4. PRF 允许不同输入输出相同, PRP 不允许。
5. PRP 的典型实例是分组密码, AES 在 128 位分组上工作。
6. 安全 PRP 在 q 远小于 $2^{(n/2)}$ 时可近似当作 PRF, 损失约为 $q^2/2^n$ 。
7. PRF 可通过不同输入生成 PRG 式长输出; PRG 也可通过 GGM 等严格构造得到 PRF。
8. 三者不是简单的强弱等级, 而是模拟不同随机对象的三类密码学工具。

14. 最终关系图

PRG: 短种子 s



长伪随机串

PRF: 密钥 k + 可选择输入 x



像随机函数一样的输出
允许不同输入发生输出碰撞

PRP: 密钥 k + 固定长度输入 x



像随机置换一样的输出
输入输出同域、可逆、无输出碰撞

关系: PRG --GGM 构造--> PRF

PRF --固定不同输入并拼接--> PRG 式输出

PRP --生日界以内近似--> PRF